SISTEMA DE GESTÃO DE QUALIDADE - SGQ

POLÍTICA DE GESTÃO DE VULNERABILIDADES
(Segurança dos Sistemas e Infraestrutura de TI da Empresa)

DOCUMENTO-MESTRE DE DIRETRIZES	VERSÃO 3.0

Seção: Diretrizes Corporativas

Natureza: Documento Institucional Neutro

Código do Documento: SGQ-POL-GVU-M

Gestão do Documento: Sistema de Gestão da Qualidade (SGQ)

Periodicidade de Revisão: Anual ou quando necessário

Próxima Rev.: Fev/2027

ÍNDICE

1. Objetivo
2. Abrangência
3. Conceito de Vulnerabilidade
4. Princípios da Gestão de Vulnerabilidades
5. Responsabilidades
6. Processo de Gestão de Vulnerabilidades
7. Conscientização e Treinamento
8. Registro, Evidências e Controle
9. Conformidade, Auditoria e Integração com Riscos
10. Disposições Finais

1. Objetivo

Estabelecer diretrizes para a identificação, avaliação, tratamento, mitigação e monitoramento de vulnerabilidades relacionadas à segurança dos sistemas, aplicações, redes e infraestrutura de tecnologia da informação, visando reduzir riscos operacionais, tecnológicos, legais, regulatórios e reputacionais.

2. Abrangência

Esta Política aplica-se a todos os sistemas internos e externos utilizados no exercício das atividades institucionais, incluindo estações de trabalho, redes, aplicações, serviços em nuvem, dispositivos e demais recursos tecnológicos, bem como a todos os colaboradores, prestadores de serviço e terceiros que interajam com esses ambientes.

3. Conceito de Vulnerabilidade

Considera-se vulnerabilidade qualquer fragilidade, falha, deficiência ou configuração inadequada em sistemas, aplicações, processos ou infraestrutura de TI que possa ser explorada de forma intencional ou acidental, resultando em comprometimento da segurança da informação, indisponibilidade de serviços ou impactos operacionais.

4. Princípios da Gestão de Vulnerabilidades

A gestão de vulnerabilidades deverá observar os seguintes princípios:

- Prevenção e atuação proativa;
- Proporcionalidade ao risco identificado;
- Prioridade baseada em impacto e criticidade;
- Continuidade operacional;
- Rastreabilidade e documentação;
- Melhoria contínua dos controles de segurança.

5. Responsabilidades

A gestão de vulnerabilidades envolve, conforme aplicável:

- **Diretoria / Administração:** apoio institucional e disponibilização de recursos;
- **Governança/Qualidade / Compliance:** coordenação das diretrizes, acompanhamento e evidências;
- **Responsáveis por TI ou Serviços Tecnológicos:** identificação, análise e tratamento técnico das vulnerabilidades;
- **Colaboradores e Prestadores de Serviço:** observância das diretrizes de segurança e comunicação de situações suspeitas.

A segregação de funções deverá ser observada sempre que possível, considerando o porte e a estrutura organizacional.

6. Processo de Gestão de Vulnerabilidades

A gestão de vulnerabilidades deverá ocorrer de forma contínua, estruturada e proporcional à realidade organizacional, observando as seguintes etapas gerais:

6.1 Identificação de Vulnerabilidades

As vulnerabilidades devem ser identificadas por meio de monitoramento, análises técnicas, atualizações de fornecedores, notificações de segurança, incidentes registrados ou outras fontes relevantes.

6.2 Avaliação e Classificação

As vulnerabilidades identificadas devem ser avaliadas quanto à sua gravidade, probabilidade de exploração e impacto potencial, permitindo a priorização adequada das ações de tratamento.

6.3 Tratamento e Mitigação

Deverão ser adotadas medidas compatíveis com o risco identificado, podendo incluir correções, atualizações, ajustes de configuração, controles compensatórios ou outras ações mitigadoras.

6.4 Monitoramento Contínuo

O ambiente tecnológico deverá ser monitorado de forma contínua, visando identificar novas vulnerabilidades, acompanhar a eficácia das medidas adotadas e reduzir riscos residuais.

7. Conscientização e Treinamento

A organização deverá promover ações de conscientização e orientação sobre segurança da informação e riscos cibernéticos, incluindo boas práticas relacionadas a:

- Uso adequado dos sistemas;
- Atualizações e correções;
- Proteção contra ameaças como phishing, malware e acessos indevidos.

As ações poderão ocorrer por meio de treinamentos, comunicados internos ou outros mecanismos adequados.

8. Registro, Evidências e Controle

As atividades relacionadas à gestão de vulnerabilidades deverão possuir registros mínimos que permitam:

- Identificação das vulnerabilidades;
- Ações adotadas;
- Acompanhamento e encerramento;
- Evidências para fins de auditoria e conformidade.

Os registros deverão ser mantidos conforme critérios internos de retenção e segurança da informação.

9. Conformidade, Auditoria e Integração com Riscos

A gestão de vulnerabilidades integra o sistema de gestão de riscos e segurança da informação, servindo como subsídio para:

- Auditorias internas e externas;
- Avaliação da eficácia dos controles;
- Revisão de políticas, procedimentos e práticas tecnológicas;
- Atendimento a requisitos legais, regulatórios e contratuais.

10. Disposições Finais

O descumprimento desta Política poderá resultar na adoção de medidas administrativas cabíveis, conforme normas internas e legislação aplicável. Esta Política entra em vigor na data de sua aprovação e deverá ser revisada periodicamente ou sempre que houver mudanças relevantes no ambiente tecnológico, regulatório ou organizacional.